

GovRed-Health: Benchmarking Authorization Drift Between Governed Disclosure and Persistent Commit

Nguyen Ngoc Thien, Trinh Minh Quang
Hai Ba Trung High School, Hue, Vietnam
Corresponding author: kakangocthen109@gmail.com

Abstract—Security benchmarks for LLM agents now cover prompt injection, tool misuse, memory attacks, and generic commit-time authorization. Persistent health AI adds a narrower failure mode: a governed disclosure may be valid when a model reads it but no longer be valid as the basis for a later persistent write because patient state, consent, policy, role, purpose, cache state, or snapshot validity has changed. We call this *authorization drift across the disclosure-to-commit interval*. GovRed-Health evaluates this failure mode with matched logical schedules that issue a governed disclosure, change one or more relevant dependencies, and then attempt persistence through the real HTTP/API, authorization, cache/index, PostgreSQL, and audit path. Research-only arms are mechanism ablations rather than claimed reproductions of prior systems. Primary endpoints are prohibited disclosure and a prespecified non-safe commit composite at the logical-schedule level, with operational failures and indeterminate concurrency reported separately. A sealed isolated run (2026-08-17-rivf-final-003) executed 270 schedules per arm. In the executable primary set ($n = 210$ per arm; protocol Not Run rows excluded), the original composite was 57.1% for Unbound, 42.9% for State-Version-Only, 42.9% for Snapshot-Bound-State-Only, and 14.3% for GLHS-Strict. Strict versus Unbound contained 90 discordant schedules favoring Strict and none favoring Unbound under that frozen composite. Crucially, all 30 Strict residuals were concurrent stale-state schedules whose linearization order could not be established, so they are reported as *indeterminate*, not confirmed stale/unauthorized commits. The tested serial authorization-drift families produced zero confirmed invalid Strict commits, and prohibited disclosure was 0/270 in every arm.

Index Terms—health AI, authorization drift, TOC-TOU, adversarial benchmark, consent, stateful agents, persistent AI

I. INTRODUCTION

Security research for LLM agents has moved beyond informal jailbreak examples toward executable benchmarks. AgentDojo evaluates prompt injection against tool-using agents [1]; Agent Security Bench covers several attack and defense families [2]; MPIB focuses on direct and RAG-mediated prompt injection in clinical tasks [3]; and SecureClaw combines sensitive-read confinement with authorization of canonical external effects [4]. These systems already cover broad adversarial testing and dual-boundary enforcement.

A second line of work is even closer to the problem studied here. Commit-time authorization shows that authority obtained earlier in an agent trajectory can become stale before a durable effect is committed [5]. Stateful governance formalizes a related concurrency problem as policy-state serializability [6], while GateMem evaluates access control and forgetting in multi-principal shared memory [7]. GovRed-Health therefore does not claim that stale authorization, governed memory, or commit-time checks are new.

The narrower health-specific problem is the status of the *disclosure actually consumed by the model*. A longitudinal health system may construct a minimized view for a specific subject, actor, purpose, consent basis, and task, then receive a model-derived proposal only after one of those conditions has changed. A later write can therefore be invalid even when the original read was legitimate. Caches, subject-scoped retrieval, and audit state can further preserve traces of authority that no longer exists.

GovRed-Health turns that interval into the experimental object. Each matched schedule follows the same pattern: *governed disclosure* $\rightarrow$ *explicit governance/state mutation* $\rightarrow$ *persistent commit attempt*, executed through the real application and persistence boundaries. The benchmark asks whether disclosure, commit, and audit outcomes remain consistent after controlled changes in consent, policy, role/purpose, subject, state version, cache state, or snapshot validity.

II. RELATED WORK AND NOVELTY BOUNDARY

Prompt- and tool-centric benchmarks. AgentDojo and Agent Security Bench provide broad agent-security test environments, while MPIB shows how prompt injection can create clinically unsafe behavior in medical and RAG tasks [1], [2], [3]. GovRed-Health includes prompt-oriented stress cases only as a secondary family; they are not its novelty claim.

Read/effect confinement. SecureClaw protects both sensitive reads and external actions [4]. GovRed-Health does not claim this two-boundary architecture as new. Instead, it treats disclosure and commit as two observable points in a controlled temporal invalidation schedule.

Temporal authorization and memory governance. Commit-time authorization and policy-state serializability establish that authorization can become stale during an

TABLE I
CROSS-BENCHMARK CAPABILITY COMPARISON: EVALUATING
COVERAGE OF THREAT DIMENSIONS IN STATEFUL CLINICAL AGENT
SECURITY.

Benchmark	Prompt Attack	Tool Access	TOCTOU Drift
AgentDojo [1]	✓	✓	
MPIB [3]	✓	×	
CommitGuard [5]	×	✓	
Provenact [6]	×	✓	
GateMem [7]	×	✓	
GovRed-Health (Ours)	✓	✓	

agent trajectory [5], [6]. GateMem establishes a benchmark for multi-principal memory governance [7]. The remaining question tested here is whether a *health disclosure already used by the model* remains a valid dependency of a later persistent proposal after patient-state or governance changes, and whether the complete path can be reconstructed across the same API, cache, database, and audit boundaries.

For this reason, we avoid claims such as “first benchmark for stateful agent security.” The contribution is narrower: a health-specific benchmark whose experimental unit contains the model-visible governed health disclosure, the intervening mutation, the later commit attempt, and the audit reconstruction of that schedule.

III. THREAT MODEL

We assume an authenticated but potentially overreaching user, stale client state, malicious content embedded in patient evidence, and concurrent legitimate updates to record or governance state. The attacker may control request text and timing but does not possess database administrator credentials or cryptographic secrets. The evaluation uses synthetic subjects and seeded sentinel values; no real patient data are required.

Let an issued disclosure snapshot be $H = (u, a, p, v_s, v_g, d, e)$, where u is subject, a actor, p purpose, v_s state version, v_g governance version, d snapshot digest, and e expiry. A later proposal P requests persistent change. A security failure occurs when the deployment releases protected information or commits P despite a violated invariant that should make the operation inadmissible.

IV. BENCHMARK DESIGN

A. System arms

The benchmark uses research-only configurations in an isolated deployment. Arm A (UNBOUND) permits model-derived writeback without snapshot/write binding. Arm B (STATE-VERSION) checks only the base state version. Arm C (SNAPSHOT-STATE) binds the proposal to a snapshot/state coordinate but does not invalidate commit on governance changes. Arm D (STRICT) revalidates state, consent/policy, actor/purpose, snapshot identity/digest, and expiry. If an arm cannot be implemented faithfully without creating a strawman, it is marked NOT RUN and excluded from superiority claims. These arms are internal

TABLE II
CORE AUTHORIZATION-DRIFT SCHEDULES AND THEIR PRIMARY
INVARIANT.

Schedule family	Expected invariant
Disclosure → consent	Revoked authority cannot license a later disclosure-derived commit.
× revoke → commit ×	Policy drift is rexalidated at durability.
× Disclosure → policy ×	
✓ update → commit ×	×
✓ Disclosure → ×	Authorization coordinates cannot silently rebind.
× actor/role/purpose ×	×
✓ change → commit ✓	✓
Disclosure → subject-crossing replay	A snapshot/proposal cannot migrate across subjects.
Disclosure → state update → stale commit	A stale base state cannot overwrite newer state.
Disclosure → revoke → cache reuse	Derived state cannot preserve revoked disclosure authority.
Snapshot → expiry/digest mutation → commit	Expired or modified disclosure witnesses are rejected.
Concurrent governance writer proposal commit	The commit outcome is consistent with the governing state at durability.
Audit reconstruction	Disclosure, mutation, decision, and persistent effect remain reconstructable.
Secondary prompt/GST-bypass stress	Model-controlled text cannot widen authority or bypass deterministic admission; reported separately from the primary drift endpoint.

mechanism ablations, not claimed replicas of AgentDojo, SecureClaw, CommitGuard, Provenact, or other published systems.

B. Real-boundary execution

Headline cases must traverse the deployed path: test client → HTTP API → authentication/authorization → retrieval/cache → governance/write gate → PostgreSQL → audit. Direct gateway calls may support debugging but are not counted as boundary evidence. Each case records the normalized response, database state before/after, relevant audit rows, sentinel occurrence, commit occurrence, response hash, and latency. Secrets and raw sensitive payloads are excluded from public artifacts.

C. Frozen instances and deterministic oracles

Each logical case is defined before the headline run by attack family, subject, actor, purpose, initial state, scheduled mutation, expected invariant, and compatible arms. Synthetic records contain unique high-entropy sentinel tokens in fields that should remain undisclosed. Oracles detect sentinel leakage, wrong-subject exposure, unauthorized commit, stale-version acceptance, revocation failure, digest/expiry acceptance, and incomplete audit reconstruction without asking an LLM to grade its own security.

Network retries do not create new samples. Repeated race attempts belonging to one logical scenario are aggregated under that scenario. The statistical unit is the frozen logical attack instance.

TABLE III

SEALED ORIGINAL COMPOSITE ENDPOINT. WILSON 95% CONFIDENCE INTERVALS REPRODUCE THE FROZEN NON-SAFE CLASSIFICATION; THE STRICT RESIDUALS ARE ALL INDETERMINATE CONCURRENT-ORDERING SCHEDULES AND ARE NOT CONFIRMED STALE/UNAUTHORIZED COMMITS.

Arm	Composite non-safe / n	Rate (95% CI)	Prohibited disclosure
Unbound	120/210	0.571 (0.504–0.636)	0/270
State-Version	90/210	0.429 (0.364–0.496)	0/270
Snapshot-State	90/210	0.429 (0.364–0.496)	0/270
Strict	30/210	0.143 (0.102–0.197)	0/270

V. ANALYSIS PLAN

Primary endpoints are attack success rate, prohibited-disclosure rate, and a frozen non-safe commit endpoint. For concurrency schedules, outcomes are additionally classified three ways as confirmed invalid/stale commit, confirmed safe/rejected, or indeterminate ordering. Indeterminate races are never relabeled as confirmed violations or confirmed safety; the original frozen composite is retained only for reproducibility. Every rate is reported with numerator, denominator, and a 95% Wilson interval. Compatible arms are run on the same logical cases; paired binary effects use exact McNemar tests where the assumptions apply. Families of prespecified arm comparisons use Holm correction. Secondary outcomes include revocation failure, wrong-subject exposure, audit-reconstruction failure, p50/p95 latency, and availability/retry cost.

The analysis distinguishes a system that safely refuses an operation from one that crashes or becomes unavailable. A defensive rejection is not counted as an attack success, whereas a transport failure is reported separately. Missing attack families or arms remain NOT RUN; they are never converted to a zero failure rate.

VI. RESULTS

The sealed run 2026-08-17-rivf-final-003 used frozen source revision 5b2c0dbf17e2cd1e31c0499cf5334f89a99cdec. The frozen protocol enumerated 450 rows per arm. Of these, 270 synthetic logical schedules were executable and ran; 180 protocol-excluded or unsupported rows remained NOT RUN. Among the 270 executed schedules, 210 belonged to the mandatory primary set and 60 were secondary/control schedules. NOT RUN rows were excluded from every denominator. The originally sealed primary composite counted any unresolved concurrent ordering as non-safe; the revision below preserves that composite for auditability but does not interpret an indeterminate race as a confirmed stale/unauthorized commit.

Under the original frozen composite, Strict versus Unbound had $b = 90$ and $c = 0$, corresponding to a paired absolute reduction of 42.9 percentage points

(approximate 95% CI 36.2–49.6 percentage points); the exact McNemar p value was 1.62×10^{-27} . This test is retained as a reproducibility result for the prespecified composite, not as proof that every residual was a confirmed invalid commit. All 30 Strict residuals belonged to the `concurrent_stale_state_write` family and had indeterminate linearization, so they are now reported separately as *indeterminate* rather than as confirmed stale/unauthorized acceptance. The serial authorization-drift families produced zero confirmed invalid Strict commits. Prohibited disclosure was 0/270 in every arm. Raw audit-completeness counts (60/270 Strict versus 120/270 Snapshot-State) are not treated as an arm-quality comparison because the arms reach different rejection/commit stages and therefore differ in audit-eligible opportunities; family-conditional auditability requires a separate denominator.

These results are controlled software robustness/governance-consistency evidence on synthetic data. The unexecuted protocol rows are not evidence of success, and the study does not establish production cybersecurity effectiveness, clinical safety, or universal concurrency correctness.

VII. DISCUSSION

GovRed-Health is designed to expose a failure that endpoint-success metrics can miss. A request can complete successfully even though the authority or governed disclosure that justified the durable effect is already stale. By keeping the disclosure, intervening mutation, commit attempt, and audit trace in the same matched schedule, the benchmark can distinguish state freshness from governance freshness and exact disclosure binding.

The sealed run supports a bounded robustness conclusion. State-only checks removed some non-safe outcomes relative to the Unbound arm, while Strict eliminated the confirmed serial authorization-drift failures exercised in the benchmark. Its 30 remaining primary residuals are not labeled failures in the causal sense: their commit/change ordering could not be established, so they remain a separate indeterminate category. This distinction is essential to the concurrency claim and prevents unresolved races from being converted into either safety or violation evidence. Likewise, observing zero prohibited disclosures in these schedules is not a general confidentiality guarantee or evidence of regulatory compliance.

The main value of the benchmark is therefore diagnostic. It shows which class of dependency a mechanism actually revalidates and where residual failures remain, rather than reducing all behavior to a single security score.

VIII. LIMITATIONS AND ETHICS

The benchmark uses synthetic data and one application architecture, so its results may not transfer directly to other EHR stacks, policy models, or persistence layers. Sentinel oracles capture observable disclosure and write-admission failures but cannot represent every privacy harm.

The downgraded arms are research-only configurations and should not be interpreted as production recommendations. The study does not evaluate clinical decision quality, patient outcomes, legal compliance, or resistance to privileged infrastructure compromise.

IX. REPRODUCIBILITY AND ARTIFACT CONTRACT

The final run records Git revision, image digest, database/schema versions, configuration and attack-manifest hashes, seeds, timestamps, raw observations, statistics-plan hash, and a SHA-256 inventory. A changed raw input or implementation creates a new run identifier. Machine-readable results and manuscript tables are generated from the same sealed artifacts.

X. CONCLUSION

GovRed-Health benchmarks authorization drift between a model-consumed governed health disclosure and a later persistent commit. Its defining unit is a frozen logical schedule that preserves the original task while changing the state or governance conditions that licensed the disclosure or write. In the sealed executable primary schedules, the original composite non-safe endpoint fell from 57.1% in the Unbound arm to 14.3% under Strict. The entire 14.3% Strict residual consisted of 30 indeterminate concurrent-ordering schedules; the tested serial authorization-drift families produced zero confirmed invalid Strict commits. Prohibited disclosure remained 0/270 in every arm. These findings support a controlled software governance-consistency claim for the tested schedules. They do not establish production cybersecurity, clinical effectiveness, or correctness for arbitrary concurrent executions.

REFERENCES

- [1] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, “AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents,” arXiv:2406.13352, 2024.
- [2] H. Zhang, J. Huang, K. Mei, et al., “Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents,” ICLR, 2025.
- [3] J. Lee, H. Jang, and K. S. Choi, “MPIB: A Benchmark for Medical Prompt Injection Attacks and Clinical Safety in LLMs,” arXiv:2602.06268, 2026.
- [4] Y. Ma and S. Schmid, “SecureClaw: Clawing Back Control of LLM Agents,” arXiv:2606.09549, 2026.
- [5] I. Santos-Grueiro, “Temporary Authority, Permanent Effects: Commit-Time Authorization for LLM Agents,” arXiv:2607.10487, 2026.
- [6] Y. Peng and X. Wu, “Stateful Governance for Concurrent Agentic Systems,” arXiv:2608.02764, 2026.
- [7] Z. Ren, Y. Yang, Y. Chen, et al., “GateMem: Benchmarking Memory Governance in Multi-Principal Shared-Memory Agents,” arXiv:2606.18829, 2026.
- [8] C. Autio et al., “Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile,” NIST AI 600-1, 2024.
- [9] OWASP GenAI Security Project, “OWASP Top 10 for LLM Applications 2025,” 2025.
- [10] S. Abdelnabi, K. Greshake, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” AISEC@CCS, pp. 79–90, 2023.
- [11] HL7 International, “FHIR R4: Consent,” 2019.
- [12] HL7 International, “FHIR R4: Provenance,” 2019.
- [13] HL7 International, “FHIR R4: RESTful API / HTTP,” 2019.
- [14] W3C, “PROV-O: The PROV Ontology,” W3C Recommendation, 2013.
- [15] P. Lewis et al., “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” NeurIPS, 2020.
- [16] N. N. Thien and T. M. Quang, “GLHS: A Co-Versioned Disclosure-to-Commit Governance Contract for Longitudinal Health AI,” working preprint, 2026.